

Dquez Carr
MCY 650
Reading Assignment
September, 2024

1. There are two ways for storing user credentials on Windows: SAM file vs domain machine/controller. What is the difference?

In a domain environment, user credentials are managed centrally on the domain controller, offering a more scalable and manageable solution compared to the localized SAM file approach used in standalone setups.

SAM File: Local to the machine, used in standalone or workgroup setups, contains credentials for local accounts only.

Domain machine/ controller: Centralized management on a domain controller, used in a domain environment, stores credentials for all users in the domain.

2. What are the different kinds of password hash schemes Windows OS used (from the past to the current version of Windows)?

LM Hash: Deprecated due to security weaknesses.

NTLM Hash: Used for a period but still has vulnerabilities.

NTLMv2 Hash: Improved security over NTLM.

Kerberos: Primary authentication protocol in modern Windows domains with strong encryption.

AES-Based Hashing: Used in recent Windows versions for enhanced security.

3. What does a SAM file look like (that is, what is the structure of the SAM file)?

C:\Windows\System32\config

4. What are the basic Kerberos exchange steps?

Client Request TGT from Authentication Server (AS) in KDC.

AS Sends TGT and Session Key back to the client.

Client decodes TGT and sends Authenticator to Ticket Granting Server (TGS) for service ticket.

TGS Issues Service Ticket and a new session key allowing access to network resources.

Client Sends Service Ticket and Authenticator to the target service.

Service Validates and Responds to the client.

5. What is the pass-the-hash attack?

Using tools like Mimikatz provided through Metasploit, attackers can steal the hash of a user that has access to a targeted server and paste it into their local security authority subsystem

'%SystemRoot%\System32\Lsass.exe' which is an executable file that stores hashes.

6. What is the difference between /bin and /sbin in Linux file system structure?

Bin directories hold binaries for general users. Sbin directories hold superuser and system binaries.

/bin Holds a lot of basic Linux commands

/sbin Holds administrative commands and is the repository for most of the routines Linux runs (known as Daemons)

7. What is the UID and GID for root users on Linux?

root:x:0:0:root:/root:/bin/bash

The root user has the highest level of privileges on the system. The values of both UID and GID are set to 0. This allows full control over the system.

8. What is a hybrid attack for password cracking?

Hybrid Attacks work the same as dictionary attacks but with a bit more ingenuity. In the hybrid attack, the cracking tool is smart enough to take words from a list and substitute numbers and symbols for alphabetic characters, perhaps a zero for an O, an @ for an a. Hybrid attacks may also attach numbers and symbols to the end of dictionary file passwords.